LADEKLAR

RECHTLICHE MUSTER

Vertrag zur Auftragsverarbeitung (AVV) nach Art. 28 Abs. 3 DSGVO

Hinweis – Muster, keine Rechtsberatung.

Vertrag zur Auftragsverarbeitung (AVV) nach Art. 28 Abs. 3 DSGVO

> **Hinweis – Muster, keine Rechtsberatung.** Dieses Dokument ist ein Mustertext für LADEKLAR. Es ersetzt keine Rechtsberatung und ist vor Verwendung anwaltlich prüfen zu lassen. Platzhalter in [eckigen Klammern] ausfüllen. Mit „Prüfhinweis“ gekennzeichnete Anmerkungen richten sich an die prüfende Anwältin bzw. den prüfenden Anwalt und sind vor Verwendung zu entfernen. Recherchestand: 16.10.2026.

zwischen

[Firma des Kunden], [Anschrift des Kunden], vertreten durch [Vertretungsberechtigte Person des Kunden] – „Verantwortlicher“ oder „Kunde“ –

und

[Firma] [Rechtsform], [Anschrift], vertreten durch [Vertretungsberechtigte Person], [Registergericht/HRB] – „Auftragsverarbeiter“ oder „Anbieter“ –

Stand: [Datum] · Version [1.0]

Präambel

Der Anbieter stellt dem Kunden die Plattform LADEKLAR als Software-as-a-Service nach den AGB, der Leistungsbeschreibung/SLA und dem jeweiligen Angebot bereit („Hauptvertrag“). Dabei verarbeitet der Anbieter personenbezogene Daten im Auftrag des Kunden. Dieser Vertrag konkretisiert die datenschutzrechtlichen Pflichten der Parteien. Er geht in Fragen des Datenschutzes dem Hauptvertrag vor. Begriffe wie „personenbezogene Daten“, „Verarbeitung“ und „Verletzung des Schutzes personenbezogener Daten“ werden im Sinne des Art. 4 DSGVO verwendet; im Übrigen gelten die Begriffe des § 2 AGB.

§ 1 Gegenstand und Dauer

(1) Gegenstand ist die Verarbeitung personenbezogener Daten durch den Anbieter im Auftrag des Kunden bei Betrieb, Bereitstellung, Wartung und Support der Plattform. Einzelheiten zu Art und Zweck der Verarbeitung, Art der Daten und Kategorien betroffener Personen enthält **Anlage 1**.

(2) Der Vertrag beginnt mit der Freischaltung des Mandanten, einschließlich der Testphase, und endet mit der vollständigen Löschung der Kundendaten nach § 11. Eine gesonderte Kündigung ist nicht erforderlich.

(3) Nicht Gegenstand dieses Vertrags ist die Verarbeitung, für die der Anbieter selbst Verantwortlicher ist, insbesondere die Daten des Kundenkontos, der Vertragsanbahnung, der Abrechnung, der Server-Protokolle zur Abwehr von Angriffen und der aggregierten Nutzungskennzahlen je Mandant ohne Personenbezug. Hierfür gilt die Datenschutzerklärung des Anbieters.

§ 2 Rollen der Parteien

(1) Der Kunde ist Verantwortlicher im Sinne des Art. 4 Nr. 7 DSGVO. Er ist für die Rechtmäßigkeit der Verarbeitung, die Information der betroffenen Personen, die Einholung von Einwilligungen und die Wahrung der Rechte der betroffenen Personen verantwortlich.

(2) Der Anbieter ist Auftragsverarbeiter im Sinne des Art. 4 Nr. 8 DSGVO.

§ 3 Weisungen

(1) Der Anbieter verarbeitet die Daten nur auf dokumentierte Weisung des Kunden, auch in Bezug auf die Übermittlung in ein Drittland, es sei denn, er ist durch Unionsrecht oder das Recht eines Mitgliedstaats zur Verarbeitung verpflichtet. In diesem Fall teilt er dem Kunden diese rechtlichen Anforderungen vor der Verarbeitung mit, sofern das betreffende Recht dies nicht wegen eines wichtigen öffentlichen Interesses verbietet (Art. 28 Abs. 3 Satz 2 lit. a DSGVO).

(2) Weisungen sind:

1. dieser Vertrag und der Hauptvertrag;
2. die vom Kunden in der Plattform gewählten Einstellungen, insbesondere zu Rollen und Rechten, Standort beim Statuswechsel, Fahrsperre, Ankunftserfassung, Fotopflicht, Unterschrift, offenen Touren und Löschfristen;
3. die Nutzung der Funktionen der Plattform durch den Kunden und seine Nutzer, insbesondere Anlegen, Ändern, Exportieren und Löschen von Daten;
4. Einzelweisungen der in **Anlage 5** benannten weisungsberechtigten Personen in Textform.

(3) Der Anbieter informiert den Kunden unverzüglich, wenn er der Auffassung ist, dass eine Weisung gegen datenschutzrechtliche Vorschriften verstößt (Art. 28 Abs. 3 Unterabs. 2 DSGVO). Er darf die Ausführung bis zur Bestätigung oder Änderung durch den Kunden aussetzen.

(4) Einzelweisungen, die über den vereinbarten Leistungsumfang hinausgehen, behandelt der Anbieter als Änderungswunsch; der Anbieter kann den Mehraufwand nach Aufwand berechnen. Weisungen zur Erfüllung von Rechten betroffener Personen bleiben im Rahmen des § 7 unberührt.

§ 4 Pflichten des Anbieters

(1) **Zweckbindung.** Der Anbieter verarbeitet die Daten ausschließlich zur Erbringung der Leistungen aus dem Hauptvertrag. Er verwendet sie nicht für eigene Zwecke, insbesondere nicht für Werbung, Profilbildung oder das Training von KI-Modellen.

(2) **Vertraulichkeit.** Der Anbieter setzt nur Personen ein, die zur Vertraulichkeit verpflichtet wurden oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen, und die mit den einschlägigen Datenschutzbestimmungen vertraut gemacht wurden (Art. 28 Abs. 3 Satz 2 lit. b, Art. 29, Art. 32 Abs. 4 DSGVO).

(3) **Sicherheit.** Der Anbieter trifft die technischen und organisatorischen Maßnahmen nach Art. 32 DSGVO, die in **Anlage 2** (TOM) beschrieben sind. Er darf die Maßnahmen an den technischen Fortschritt anpassen, sofern das Schutzniveau nicht unterschritten wird. Wesentliche Änderungen dokumentiert er und teilt sie dem Kunden mit.

(4) **Keine Einsicht in Auftragsdaten.** Die Plattform ist so gestaltet, dass Mitarbeiter des Anbieters über die Plattform-Konsole keine Auftragsdaten einsehen können. Zugriffe auf Auftragsdaten erfolgen ausschließlich

1. im Rahmen eines vom Kunden freigegebenen Support-Zugriffs nach **Anlage 4**,
2. bei der Wiederherstellung aus Datensicherungen auf Anforderung des Kunden oder zur Behebung einer Störung, oder
3. wenn dies zur Abwehr einer akuten Gefahr für die Sicherheit der Plattform zwingend erforderlich ist; in diesem Fall informiert der Anbieter den Kunden unverzüglich und dokumentiert Anlass, Umfang und handelnde Person.

Administrative Zugriffe auf Server und Datenbank sind auf [Anzahl] namentlich benannte Personen beschränkt und werden protokolliert.

(5) **Datenschutzbeauftragter.** Der Anbieter teilt dem Kunden die Kontaktdaten seines Datenschutzkontakts bzw. – falls benannt – seines Datenschutzbeauftragten mit: [Datenschutzkontakt].

(6) **Verzeichnis.** Der Anbieter führt ein Verzeichnis aller Kategorien von Verarbeitungstätigkeiten im Auftrag nach Art. 30 Abs. 2 DSGVO.

(7) **Ort der Verarbeitung.** Die Verarbeitung erfolgt in Rechenzentren in Deutschland. Eine Verlagerung in einen anderen Mitgliedstaat der EU oder des EWR teilt der Anbieter dem Kunden vorher mit. Für Drittländer gilt § 6.

(8) **Zusammenarbeit mit Behörden.** Der Anbieter arbeitet auf Anfrage mit der Aufsichtsbehörde zusammen und informiert den Kunden unverzüglich über Kontrollhandlungen und Maßnahmen der Aufsichtsbehörde, soweit sie sich auf diesen Auftrag beziehen.

§ 5 Unterauftragsverarbeiter

(1) Der Kunde erteilt dem Anbieter die allgemeine Genehmigung, Unterauftragsverarbeiter einzusetzen (Art. 28 Abs. 2 Satz 1 DSGVO). Die bei Vertragsschluss eingesetzten Unterauftragsverarbeiter ergeben sich aus **Anlage 3** und gelten als genehmigt.

(2) Der Anbieter informiert den Kunden mindestens [30] Tage vor der Hinzuziehung oder dem Austausch eines Unterauftragsverarbeiters in Textform und über die Plattform. Der Kunde kann innerhalb dieser Frist aus wichtigem datenschutzrechtlichem Grund in Textform widersprechen. Können sich die Parteien nicht einigen, kann der Kunde den Hauptvertrag zum Zeitpunkt des geplanten Einsatzes außerordentlich kündigen; § 17 und § 18 AGB gelten.

(3) In dringenden Fällen (z. B. Ausfall eines Unterauftragsverarbeiters, Sicherheitsgründe) kann der Anbieter einen Unterauftragsverarbeiter mit gleichwertigem Schutzniveau vorläufig ohne Vorankündigung einsetzen; er informiert den Kunden unverzüglich. Das Widerspruchsrecht nach Abs. 2 gilt entsprechend.

(4) Der Anbieter erlegt jedem Unterauftragsverarbeiter durch Vertrag dieselben Datenschutzpflichten auf, die in diesem Vertrag festgelegt sind, insbesondere hinreichende Garantien für geeignete technische und organisatorische Maßnahmen (Art. 28 Abs. 4 DSGVO). Er prüft die Garantien vor Beginn und danach regelmäßig. Kommt ein Unterauftragsverarbeiter seinen Pflichten nicht nach, haftet der Anbieter gegenüber dem Kunden für dessen Pflichterfüllung.

(5) Der Anbieter stellt dem Kunden auf Anfrage die Informationen zur Verfügung, die der Kunde benötigt, um die Garantien der Unterauftragsverarbeiter zu prüfen, einschließlich der ihm bekannten weiteren Unterauftragsverarbeiter in der Kette.

(6) Keine Unterauftragsverhältnisse im Sinne dieses Paragraphen sind Nebenleistungen, bei denen der Dienstleister keinen Zugriff auf personenbezogene Daten im Auftrag hat, z. B. Telekommunikations- und Transportleistungen, Reinigungs- oder Prüfdienste ohne Datenzugriff. Der Anbieter trifft auch hier angemessene vertragliche Vorkehrungen.

> **Prüfhinweis:** Der EDSA hat in seiner Stellungnahme 22/2024 (07.10.2024) betont, dass der Verantwortliche die Garantien seiner (Unter-)Auftragsverarbeiter nachweisen können muss, und Informationen über die Kette verlangt. Abs. 5 trägt dem Rechnung. Zur Einordnung der Push-Dienste (Google, Apple, Mozilla, Microsoft) siehe Anlage 3 und UNTERAUFTRAGSVERARBEITER.md.

§ 6 Übermittlung in Drittländer

(1) Eine Übermittlung personenbezogener Daten in ein Land außerhalb der EU bzw. des EWR erfolgt nur, wenn die Voraussetzungen der Art. 44 ff. DSGVO erfüllt sind, insbesondere auf Grundlage eines Angemessenheitsbeschlusses (Art. 45 DSGVO) oder geeigneter Garantien wie der Standardvertragsklauseln der Kommission (Art. 46 Abs. 2 lit. c DSGVO).

(2) Bei Vertragsschluss findet eine Übermittlung in Drittländer nur im Zusammenhang mit Push-Benachrichtigungen statt (Anlage 3). Für Übermittlungen in die USA an zertifizierte Unternehmen gilt der Angemessenheitsbeschluss der Kommission zum EU-US Data Privacy Framework vom 10.07.2023.

(3) Erhält der Anbieter ein Herausgabeverlangen einer Behörde eines Drittlands, prüft er dessen Rechtmäßigkeit, informiert den Kunden, soweit dies zulässig ist, und gibt Daten nur heraus, soweit er dazu nach dem anwendbaren Recht verpflichtet ist.

> **Prüfhinweis:** Das Gericht der EU hat die Klage gegen den Angemessenheitsbeschluss zum Data Privacy Framework am 03.09.2025 abgewiesen (T-553/23, Latombe). Das Rechtsmittel ist beim EuGH anhängig (C-703/25 P); eine Entscheidung lag am 16.10.2026 nach Recherche nicht vor. Die Zertifizierung jedes US-Empfängers ist in der offiziellen DPF-Liste zu prüfen; als Rückfallebene sollten Standardvertragsklauseln vereinbart sein.

§ 7 Unterstützung bei Rechten betroffener Personen

(1) Der Anbieter unterstützt den Kunden mit geeigneten technischen und organisatorischen Maßnahmen bei der Erfüllung der Rechte betroffener Personen nach Kapitel III DSGVO (Art. 28 Abs. 3 Satz 2 lit. e DSGVO).

(2) Die Plattform stellt hierfür insbesondere bereit: Suche und Export der Daten einer Person (z. B. eines Fahrers), Berichtigung von Stammdaten, Löschung und Deaktivierung von Nutzern, Datenexport in maschinenlesbarem Format.

(3) Wendet sich eine betroffene Person direkt an den Anbieter, leitet er das Anliegen unverzüglich an den Kunden weiter und beantwortet es nicht selbst, es sei denn, der Kunde weist ihn dazu an.

(4) Unterstützungsleistungen, die über die Funktionen der Plattform hinausgehen, vergütet der Kunde nach Aufwand, sofern der Anlass nicht auf einem Verstoß des Anbieters beruht.

§ 8 Unterstützung bei den Pflichten nach Art. 32 bis 36 DSGVO

(1) Der Anbieter unterstützt den Kunden unter Berücksichtigung der Art der Verarbeitung und der ihm zur Verfügung stehenden Informationen bei der Einhaltung der Pflichten nach Art. 32 bis 36 DSGVO, insbesondere bei Datenschutz-Folgenabschätzungen und vorherigen Konsultationen.

(2) Der Anbieter stellt dem Kunden hierfür eine Beschreibung der Plattform, der Datenflüsse, der TOM und der Unterauftragsverarbeiter zur Verfügung.

§ 9 Meldung von Verletzungen des Schutzes personenbezogener Daten

(1) Der Anbieter meldet dem Kunden eine Verletzung des Schutzes personenbezogener Daten, die Daten des Kunden betrifft, unverzüglich, spätestens innerhalb von [24] Stunden, nachdem ihm die Verletzung bekannt geworden ist (Art. 33 Abs. 2 DSGVO), an die in Anlage 5 benannte Stelle.

(2) Die Meldung enthält, soweit bekannt:

1. eine Beschreibung der Art der Verletzung, möglichst mit Kategorien und ungefährer Zahl der betroffenen Personen und Datensätze;
2. Name und Kontaktdaten des Datenschutzkontakts des Anbieters;
3. eine Beschreibung der wahrscheinlichen Folgen;
4. eine Beschreibung der ergriffenen oder vorgeschlagenen Maßnahmen zur Behebung und zur Abmilderung.

Informationen, die zum Zeitpunkt der Meldung nicht vorliegen, reicht der Anbieter unverzüglich nach.

(3) Der Anbieter unterstützt den Kunden bei dessen Meldung an die Aufsichtsbehörde innerhalb von 72 Stunden (Art. 33 Abs. 1 DSGVO) und bei der Benachrichtigung betroffener Personen (Art. 34 DSGVO). Meldungen an Aufsichtsbehörden und Benachrichtigungen betroffener Personen nimmt der Anbieter nur auf Weisung des Kunden vor.

(4) Der Anbieter trifft unverzüglich die erforderlichen Maßnahmen zur Sicherung der Daten und zur Minderung möglicher nachteiliger Folgen und dokumentiert die Verletzung.

> **Prüfhinweis:** Der Digital Omnibus (Vorschlag vom 19.11.2025) sieht vor, die Meldepflicht an die Aufsichtsbehörde auf Fälle mit voraussichtlich hohem Risiko zu beschränken und die Frist auf 96 Stunden zu verlängern. Der Vorschlag war am 16.10.2026 nach Recherche nicht verabschiedet; die Regelung folgt dem geltenden Recht.

§ 10 Nachweise und Kontrollen

(1) Der Anbieter stellt dem Kunden alle erforderlichen Informationen zum Nachweis der Einhaltung der Pflichten aus Art. 28 DSGVO zur Verfügung und ermöglicht Überprüfungen einschließlich Inspektionen durch den Kunden oder einen von ihm beauftragten Prüfer (Art. 28 Abs. 3 Satz 2 lit. h DSGVO).

(2) Der Nachweis kann insbesondere erbracht werden durch

1. die aktuelle Fassung der TOM,
2. Zertifikate der Rechenzentren (z. B. ISO/IEC 27001),
3. Berichte unabhängiger Prüfer oder eine Selbstauskunft in Form eines Sicherheitsfragebogens,

4. Auszüge aus dem Protokoll der Support- und Administrationszugriffe.

(3) Vor-Ort-Kontrollen sind mit einer Frist von mindestens [vier] Wochen anzukündigen, finden während der Geschäftszeiten statt, dürfen den Betrieb nicht unverhältnismäßig stören und Daten anderer Kunden nicht offenlegen. Prüfer sind zur Vertraulichkeit zu verpflichten und dürfen keine Wettbewerber des Anbieters sein. Kontrollen finden in der Regel höchstens einmal je Kalenderjahr statt, es sei denn, es besteht ein konkreter Anlass (z. B. eine Datenschutzverletzung) oder eine Aufsichtsbehörde verlangt sie.

(4) Der Anbieter kann für Kontrollen, die über die Bereitstellung der Unterlagen nach Abs. 2 hinausgehen, eine angemessene Vergütung seines Aufwands verlangen, es sei denn, die Kontrolle hat einen Verstoß des Anbieters ergeben.

§ 11 Löschung und Rückgabe nach Ende der Leistungen

(1) Nach Abschluss der Leistungen und nach Ablauf des Abrufzeitraums bzw. Datenabrufzeitraums (§ 17 und § 18 AGB), in dem der Kunde seine Daten selbst vollständig exportieren kann, löscht der Anbieter alle personenbezogenen Daten des Kunden, sofern nicht nach Unionsrecht oder dem Recht eines Mitgliedstaats eine Verpflichtung zur Speicherung besteht (Art. 28 Abs. 3 Satz 2 lit. g DSGVO).

(2) Die Löschung im Produktivsystem erfolgt innerhalb von [30] Tagen nach Ablauf des Abrufzeitraums. Datensicherungen werden im regulären Zyklus von 30 Tagen überschrieben. Der Anbieter bestätigt die Löschung auf Verlangen in Textform.

(3) Während der Vertragslaufzeit löscht die Plattform Daten nach den vom Kunden festgelegten Löschfristen automatisch (Leistungsbeschreibung Teil A Ziffer 6).

§ 12 Haftung

Für die Haftung gelten Art. 82 DSGVO sowie im Innenverhältnis die Haftungsregelungen des Hauptvertrags (§ 20 AGB), soweit nicht zwingendes Recht entgegensteht.

§ 13 Schlussbestimmungen

(1) Änderungen und Ergänzungen dieses Vertrags bedürfen der Textform.

(2) Sollten Daten des Kunden beim Anbieter durch Pfändung, Beschlagnahme, ein Insolvenzverfahren oder sonstige Ereignisse oder Maßnahmen Dritter gefährdet werden, informiert der Anbieter den Kunden unverzüglich und weist die Dritten darauf hin, dass die Hoheit über die Daten beim Kunden als Verantwortlichem liegt.

(3) Ein Zurückbehaltungsrecht an den Daten des Kunden ist ausgeschlossen.

(4) Sollte eine Bestimmung unwirksam sein, bleibt die Wirksamkeit der übrigen Bestimmungen unberührt.

(5) Es gilt deutsches Recht. Gerichtsstand ist der Gerichtsstand des Hauptvertrags.

(6) Dieser Vertrag kann elektronisch geschlossen werden (Art. 28 Abs. 9 DSGVO).

[Ort, Datum] – Kunde: _____

[Ort, Datum] – Anbieter: _____

Anlage 1 – Beschreibung der Verarbeitung

1.1 Art und Zweck der Verarbeitung

Art	Zweck
Hosting, Speicherung und Sicherung	Bereitstellung der Plattform und ihrer Daten, Wiederherstellung nach Störungen
Verarbeitung im Rahmen der Funktionen	Planung und Zuweisung von Lieferungen, Statusmeldungen, Live-Übersicht, Benachrichtigungen, Dokumentation der Ablieferung (Abliefernachweis), Berechnung von Standzeiten, Fahrzeugverwaltung, Berichte, Export
Authentifizierung und Rechteprüfung	Schutz der Zugänge, Mandantentrennung
Protokollierung	Nachvollziehbarkeit von Änderungen und Zugriffen (Audit-Log), Sicherheit
Versand von Benachrichtigungen	Push-Benachrichtigungen und System-E-Mails (z. B. Einladung, Passwort zurücksetzen)
Support	Analyse und Behebung von Störungen nach Freigabe (Anlage 4)
Löschung	Umsetzung der Löschfristen und Löschung nach Vertragsende

1.2 Kategorien personenbezogener Daten

Nr.	Kategorie	Beispiele
1	Stammdaten der Fahrer	Name, Handynummer, Sprache, Führerscheinklasse, Rolle, Status, zugeordnetes Fahrzeug und Auflieger, PIN-Hash
2	Stammdaten der Admins und Disponenten	Name, E-Mail, Telefon, Rolle, Passwort-Hash
3	Kontaktdaten an Lade- und Entladestellen	Name des Ansprechpartners, Telefonnummer, Adresse, Zeitfenster
4	Auftragsdaten	Buchungsnummer, Auftraggeber, Kundenreferenz, Route, Ware, Paletten, Gewicht, Gefahrgut, Temperatur, Hinweise, Zuweisung, Status, Zeitpunkte
5	Ereignis- und Verlaufsdaten	Statusschritte mit Zeitpunkt und handelnder Person, Rücknahmen, Rückgaben mit Grund, Notizen, Problemmeldungen, Palettentausch, Ankunftszeiten und Standzeiten
6	Fotos und Dokumente	Lieferschein-Fotos, PDF-Dokumente, Fotos zu Problemmeldungen (z. B. Schäden); diese können Namen, Unterschriften und Adressen Dritter enthalten
7	Empfängerangaben und Unterschriften	Name des Empfängers, Unterschrift auf dem Display (Bilddatei), Zeitpunkt
8	optionale Standortdaten	Koordinaten und Genauigkeit im Moment eines Statuswechsels, nur wenn vom Kunden eingeschaltet und vom Fahrer freigegeben
9	Protokolldaten	Anmeldungen, fehlgeschlagene Anmeldeversuche, Änderungen, Exporte, Support-Zugriffe, jeweils mit Zeitpunkt, Nutzer und IP-Adresse
10	Geräte- und Push-Daten	Push-Abonnement (Endpunkt-URL des Push-Dienstes, öffentlicher Schlüssel), Sitzungskennung (gehasht), Gerätetyp und Browser
11	Fahrzeugdaten mit Personenbezug	Kennzeichen, Belegung durch einen Fahrer, Fristen

Nr.	Kategorie	Beispiele
12	Berichtsdaten	Lieferungen je Fahrer und Monat, Pünktlichkeit, Standzeiten

Besondere Kategorien personenbezogener Daten (Art. 9 DSGVO) sind nicht Gegenstand der Verarbeitung. Sie können ausnahmsweise in Freitexten oder Fotos enthalten sein (z. B. Angaben zu Verletzungen bei einer Unfallmeldung); der Kunde wirkt darauf hin, dass dies unterbleibt, soweit es nicht erforderlich ist.

1.3 Kategorien betroffener Personen

1. Fahrer des Kunden (Beschäftigte, Leiharbeitnehmer, Aushilfen);
2. Fahrer von Subunternehmern des Kunden;
3. Admins und Disponenten des Kunden;
4. Ansprechpartner der Auftraggeber sowie an Lade- und Entladestellen;
5. Empfänger von Sendungen, die unterschreiben oder auf Lieferdokumenten genannt sind;
6. sonstige Personen, deren Daten auf Lieferdokumenten enthalten sind.

1.4 Dauer

Für die Dauer des Hauptvertrags einschließlich Testphase und Abrufzeitraum; Löschung nach § 11.

Anlage 2 – Technische und organisatorische Maßnahmen

Es gilt das Dokument „Technische und organisatorische Maßnahmen (TOM)“ in der jeweils aktuellen Fassung (Datei `TOM.md`, abrufbar unter [Website-URL/tom]).

Anlage 3 – Unterauftragsverarbeiter

Es gilt die Liste der Unterauftragsverarbeiter in der jeweils aktuellen Fassung (Datei `UNTERAUFTRAGSVERARBEITER.md`, abrufbar unter [Website-URL/unterauftragsverarbeiter]). Stand bei Vertragsschluss:

Nr.	Unterauftragsverarbeiter	Leistung	Ort
1	[Hosting-Anbieter], [Anschrift]	Rechenzentrum, Server, Speicher	Deutschland
2	[Backup-Anbieter], [Anschrift]	verschlüsselte Datensicherung	Deutschland
3	[E-Mail-Versanddienst], [Anschrift]	Versand von System-E-Mails	[EU/Deutschland]
4	Push-Dienste der Browser- und Betriebssystemhersteller	Zustellung von Push-Benachrichtigungen (verschlüsselte Nutzlast)	EU/USA, siehe Liste

---

Anlage 4 – Verfahren für den Support-Zugriff

(1) **Grundsatz.** Mitarbeiter des Anbieters haben keinen Zugriff auf Auftragsdaten. Ein Support-Zugriff auf den Mandanten setzt eine Freigabe durch einen Admin des Kunden voraus.

(2) **Freigabe.** Der Admin erteilt die Freigabe in den Einstellungen der Plattform. Er wählt die Dauer (Voreinstellung [24] Stunden, höchstens [7] Tage). Die Plattform speichert das Ende der Freigabe (`supportAccessUntil`). Nach Ablauf erlischt der Zugriff automatisch. Der Admin kann die Freigabe jederzeit vorzeitig widerrufen.

(3) **Umfang.** Der Support-Zugriff erlaubt das Lesen der Daten des Mandanten, soweit dies für die Analyse des gemeldeten Anliegens erforderlich ist. Änderungen nimmt der Anbieter nur auf ausdrückliche Weisung in Textform vor. Exporte von Auftragsdaten durch den Anbieter sind ausgeschlossen.

(4) **Personen.** Den Support-Zugriff dürfen nur namentlich benannte und auf Vertraulichkeit verpflichtete Mitarbeiter des Anbieters nutzen, die sich mit [Zwei-Faktor-Authentifizierung] anmelden.

(5) **Protokollierung.** Beginn und Ende der Freigabe, jede Anmeldung im Support-Modus und jede Änderung werden mit Zeitpunkt und Mitarbeiter im Audit-Log des Mandanten gespeichert. Der Admin kann das Protokoll jederzeit einsehen und exportieren.

(6) **Ticketbezug.** Jeder Support-Zugriff ist einem Support-Vorgang zugeordnet. Nach Abschluss teilt der Anbieter dem Kunden mit, welche Maßnahmen er vorgenommen hat.

> **Prüfhinweis (Technik):** Zwei-Faktor-Authentifizierung für die Plattform-Konsole und den Support-Modus sowie die Kennzeichnung „nur Lesen“ als Anforderungen mit der Umsetzung abgleichen.

Anlage 5 – Kontakte und weisungsberechtigte Personen

Rolle	Kunde	Anbieter
weisungsberechtigt bzw. weisungsempfangend	[Name, Funktion, E-Mail, Telefon]	[Name, Funktion, E-Mail, Telefon]
Vertretung	[Name, Funktion, E-Mail, Telefon]	[Name, Funktion, E-Mail, Telefon]
Datenschutzbeauftragter bzw. Datenschutzkontakt	[Name, E-Mail]	[Datenschutzkontakt]
Meldestelle für Datenschutzverletzungen	[E-Mail, Telefon]	[Sicherheits-E-Mail], [Telefon]

Änderungen teilen die Parteien einander unverzüglich in Textform mit.